

4.6 其他安全性保护

为满足较高安全等级数据库管理系统的安全性保护要求,在自主存取控制和强制存取控制之外,还有推理控制以及数据库应用中的隐蔽信道和数据隐私等技术。

1. 推理控制

推理控制(inference control)处理的是强制存取控制未解决的问题。例如,利用属性之间的函数依赖关系,用户能从低安全等级信息推导出其无权访问的高安全等级信息,进而导致信息泄露。

数据库推理控制机制用来避免用户利用其能够访问的数据推知更高密级的数据,即用户利用其被允许的多次查询结果,结合相关领域背景知识以及数据之间的约束,推导出其不能访问的数据。在推理控制方面,常用的方法如基于函数依赖的推理控制和基于敏感关联的推理控制等。例如,某公司信息系统中假设姓名和职务属于低安全等级(如公开)信息,而工资属于高安全等级(如机密)信息。用户A的安全等级较低,他通过授权可以查询自己的工资、姓名、职务,及其他用户的姓名和职务。由于工资是机密信息,因此用户A不应知道其他用户的工资。但是,若用户B的职务和用户A相同,则利用函数依赖关系职务 $\rightarrow$ 工资,用户A可通过自己的工资信息(假设3000元),推出B的工资也是3000元,从而导致高安全等级的敏感信息泄露。

2. 隐蔽信道

隐蔽信道(covert channel)处理的内容也是强制存取控制未解决的问题。下面的例子就是利用未被强制存取控制的SQL语句执行后反馈的信息进行了间接信息传递。

一般情况下,如果INSERT语句对UNIQUE属性列写入重复值,则系统会报错且操作失败。那么,针对UNIQUE约束列,高安全等级用户(发送者)可先向该列插入(或不插入)数据,而低安全等级用户(接收者)后向该列插入相同数据。

如果插入失败,则表明发送者已向该列插入数据,此时二者约定发送者传输信息位为0;如果插入成功,则表明发送者未向该列插入数据,此时二者约定发送者传输信息位为1。通过这种方式,高安全等级用户按事先约定方式主动向低安全等级用户传输信息,使得信息流从高安全等级向低安全等级流动,从而导致高安全等级敏感信息泄露。

3. 数据隐私

随着人们对隐私的重视,数据隐私成为数据库应用中新的数据保护模式。

数据隐私是控制不愿被他人知道或他人不便知道的个人数据的能力。数据隐私范围很广,涉及数据管理中的数据收集、数据存储、数据发布和数据发布等各个阶段。例如,在数据存储阶段应避免非授权的用户访问个人的隐私数据。通常可以使用数据库安全技术实现这一阶段的隐私保护。如使用自主访问控制、强制访问控制和基于角色的访问控制以及数据加密等。在数据处理阶段,需要考虑数据推理带来的隐私数据泄露。非授权用户可能通过分析多次查询的结

果,或基于完整性约束信息推导出其他用户的隐私数据。在数据发布阶段,应使包含隐私的数据发布结果满足特定的安全性标准。如发布的关系数据表首先不能包含原有表的候选码,同时还要考虑准标识符的影响。

准标识符是能够唯一确定大部分记录的属性集合。在现有安全性标准中, k 匿名(k -anonymization)标准要求每个具有相同准标识符的记录组至少包括 k 条记录,从而控制攻击者判别隐私数据所属个体的概率。还有 l 多样性(l -diversity)标准、 t 临近(t -closeness)标准等,从而使攻击者不能从发布数据中推导出额外的隐私数据。数据隐私也是当前研究的热点。

4. “三权分立”的安全管理机制

在传统的数据库安全模型中,数据库管理员通常是具有极大权限的超级用户。而不对数据库管理员进行任何权限检查,实际上为数据库中的数据安全带来了隐患。为了解决数据库管理员权限过于集中的问题,遵照国家标准《信息安全技术 数据库管理系统安全技术要求》(GB/T 20273—2019),引进了“三权分立”的安全管理机制。详细介绍可参见二维码内容。



扩展阅读:三权分立的
安全管理机制

要想万无一失地保证数据库安全,使之免于遭到任何蓄意的破坏,几乎是不可能的。但严密的安全措施将使蓄意的攻击者付出高昂的代价,从而迫使攻击者不得不放弃其破坏企图。

本章小结

随着数据库应用的日益广泛和深入,以及计算机网络的发展,数据的安全保密越来越重要。数据库管理系统是管理数据的核心,因而其自身必须具有一整套完整而有效的安全性机制。

实现数据库系统安全性的技术和方法有多种,数据库管理系统提供的安全措施主要包括用户身份鉴别、入侵检测、自主存取控制和强制存取控制技术、视图技术和审计技术、数据存储加密和传输加密等技术。本章全面讲解了这些技术。

当前,数据库新技术的发展和应用使数据库安全性面临新的挑战,数据库安全保护技术的研究、创新和产品研发没有止境。

习 题 4

1. 什么是数据库的安全性?
2. 举例说明对数据库安全性产生威胁的因素。
3. 试述实现数据库安全性控制的常用方法和技术。
4. 什么是数据库中的自主存取控制方法和强制存取控制方法?
5. 对下列两个关系模式:

学生(学号,姓名,年龄,性别,家庭住址,班级号)

班级(班级号,班级名,班主任,班长)

请用 SQL 的 GRANT 语句完成下列授权功能:

- ① 授予用户 U1 对两个表的所有权限,并可给其他用户授权。
 - ② 授予用户 U2 对“学生”表具有查看权限,对“家庭住址”具有更新权限。
 - ③ 将对“班级”表查看权限授予所有用户。
 - ④ 将对“学生”表的查询、更新权限授予角色 R1。
 - ⑤ 将角色 R1 授予用户 U1,并且 U1 可继续授权给其他角色。
6. 今有以下两个关系模式:

职工(职工号,姓名,年龄,职务,工资,部门号)

部门(部门号,名称,经理名,地址,电话号)

请用 SQL 的 GRANT 语句和 REVOKE 语句(加上视图机制)实现以下授权定义或存取控制功能:

- ① 用户王明对两个表有 SELECT 权限。
 - ② 用户李勇对两个表有 INSERT 和 DELETE 权限。
 - ③ 每个职工只对自己的记录有 SELECT 权限。
 - ④ 用户刘星对职工表有 SELECT 权限,对“工资”字段具有更新权限。
 - ⑤ 用户张新具有修改这两个表的结构权限。
 - ⑥ 用户周平具有对两个表的所有权限,并具有给其他用户授权的权限。
 - ⑦ 用户杨兰具有从每个部门职工中 SELECT 最高工资、最低工资、平均工资的权限,但不能查看每个人的工资。
7. 针对第 6 题中①~⑦的每一种情况,撤销各用户所授予的权限。
8. 理解并解释强制存取控制机制中主体、客体、敏感度标记的含义。
9. 举例说明强制存取控制机制是如何确定主体能否存取客体的。
10. 什么是数据库的审计功能,为什么要提供审计功能?

第 4 章实验 安全性控制

实验 4.1 自主存取控制实验。理解和掌握自主存取控制权限的定义和维护方法,包括定义用户、定义角色、分配权限给用户、分配权限给角色和回收权限等基本功能。使用用户名登录数据库,验证权限分配是否正确。

***实验 4.2 审计实验。**掌握数据库审计的设置和管理方法,以便监控数据库操作,维护数据库安全,包括设置数据库审计开关、审计数据库对象、审计数据库语句、查看数据库审计记录,以及验证审计设置是否生效。

参考文献 4

- [1] US Department of Defense. Department of defense trusted computer system evaluation criteria [M]. The 'Or-

ange Book' Series, 1985.

[2] NCSC. Trusted database management system interpretation(TDI)[R], 1991.

[3] GRIFFITHS P P, WADE B W. An authorization mechanism for a relational database system[J]. ACM Transactions on Database Systems, 1976, 1(3): 242-255.

文献[3]讨论了 SYSTEM R 的授权机制。关系数据库系统原型 SYSTEM R 首先提出了授权和收回权力的概念。

[4] 刘启原, 刘怡. 数据库与信息系统的的核心[M]. 北京: 科学出版社, 2000.

文献[4]系统讲解了信息系统的的核心问题, 包括安全模型、与安全有关的标准、密码学与信息保密、攻击检测技术和理论、数据库的安全性、数据仓库的安全问题、网络安全问题、Java 语言及其核心问题、信息安全和病毒问题等。

[5] 张孝. 可信 COBASE 的系统强制存取控制的设计与实现[D]. 北京: 中国人民大学, 1998.

文献[5]系统讨论了数据库系统的核心问题, 给出了可信 COBASE 的系统设计和实现技术。可信 COBASE 是 COBASE 2.0 的安全版本, 它依据 TCSEC/TDI 对 B1 级的要求进行设计, 实现了强制存取控制和安全审计。

[6] 张俊, 彭朝晖, 肖艳芹, 等. DBMS 安全性评估保护轮廓 PP 的研究与开发[C]//中国计算机学会: 第 22 届全国数据库学术会议论文集(技术报告篇), 计算机科学, 2005: 72-75, 79.

文献[6]在深入研究 CC 以及国外主流 DBMS CC 安全性评估情况的基础上, 总结出 DBMS PP 的开发原则和方法, 并初步研究和开发了一个 EAL4 级 DBMS PP。根据该 PP 对 Kingbase ES 进行安全性开发、测试和内部评估, 取得了良好的效果。

[7] 张效祥, 徐家福. 计算机科学技术百科全书[M]. 3 版. 北京: 清华大学出版社, 2018.

[8] 国家市场监督管理总局, 中国国家标准化管理委员会. 信息安全技术数据库管理系统安全技术要求: GB/T 20273-2019[S]. 北京: 中国标准出版社, 2019.

本章知识点讲解微视频:



用户身份鉴别



权限的表达与检查



强制访问控制

数据库的完整性是指数据库数据的正确性 (correctness) 和相容性 (compatibility)。数据的正确性是指数据库数据符合现实世界语义且反映当前的实际状况。数据的相容性是指数据库同一对象在不同关系表中的数据是相同的, 一致的。

本章导读

本章系统地讲解关系数据库管理系统完整性实现的机制, 包括完整性约束的定义机制、检查方法和违约处理方法等。

实体完整性和参照完整性是关系系统的两个不变性, 即关系模型必须具备的完整性约束。其他完整性约束则可以归入用户定义的完整性, 由现实世界语义约束确定。

完整性约束作为数据库模式的一部分存入数据字典, 在数据库数据被修改时, 关系数据库管理系统的完整性约束检查机制将按照数据字典中定义的这些约束进行检查和处理。数据库完整性的定义可由 SQL 的数据定义语言 (DDL) 实现。

本章还讲解了触发器 (trigger), 触发器可以实施更为复杂的完整性定义、检查和违约操作, 具有更精细和更强大的数据控制能力。因为触发器规则中的动作体可以很复杂, 通常是一段过程化 SQL。

读者要通过上机实验掌握 SQL 的完整性约束定义功能、属性和元组完整性约束的定义语句, 能够验证完整性约束检查机制是否发挥作用, 掌握违约处理方法。进一步地, 要掌握触发器的概念, 并能使用触发器实现更复杂的完整性控制方法。

5.1 数据库完整性概述

数据库的完整性是指数据库数据的正确性和相容性。例如, 学生的学号必须唯一, 学生的性别只能是男或女, 百分制的课程成绩取值范围为 0~100, 学生所选的课程必须是学校开设的课程, 学生所在的院系必须是学校已成立的院系等。